Davante

2

CIBERSEGURIDAD

Medidas de seguridad pasiva

ÍNDICE

1. Introducción y contextualización práctica 3

2. Pautas de seguridad informática 4

2. 1. Adopción de las pautas 5

2. 2. Impactos y repercusión 5

3. Caso práctico 1: "Implementamos medidas de seguridad en nuestra red doméstica" 6

4. Seguridad física y ambiental 7

4. 1. Ubicación y protección física de los equipos y servidores 8

4. 2. Plan de seguridad física 9

4. 3. Plan de recuperación en caso de desastres 10

5. Caso práctico 2: "Ideamos nuestro plan de seguridad física" 10

6. Sistemas de alimentación ininterrumpida (SAI) 11

6. 1. Funciones 11

6. 2. Tipos 12

7. Resumen y resolución del caso práctico de la unidad 12

8. Bibliografía 14

© Davante 978-84-10384-03-3

Reservados todos los derechos. Queda rigurosamente prohibida, sin la autorización escrita de los titulares del copyright, bajo las sanciones establecidas en las leyes, la reproducción, transmisión y distribución total o parcial de esta obra por cualquier medio o procedimiento, incluidos la reprografía y el tratamiento informático.

Objetivos

Conocer los principales sistemas para la seguridad pasiva.

Entender la importancia de estos sistemas para la seguridad informática.

1. Introducción y contextualización práctica

En la era digital, donde la información y los datos se han convertido en activos de vital importancia, la seguridad es una preocupación fundamental para personas, empresas y organizaciones en general. La protección de los sistemas y la información que contienen se ha vuelto una tarea crítica para salvaguardar la integridad, confidencialidad y disponibilidad de los datos.

Dentro del amplio campo de la seguridad informática, una de las estrategias fundamentales es la implementación de medidas de seguridad pasiva. Estas medidas se centran en la detección y respuesta de los sistemas, con el objetivo de reducir el impacto en caso de incidentes o ataques.

En contraste con las medidas de seguridad activa, que implican el fortalecimiento de las defensas y barreras de seguridad antes de que ocurra un incidente, las medidas de seguridad pasiva se centran en la respuesta a eventos. Estas medidas abarcan una amplia gama de prácticas, políticas y tecnologías que se implementan tanto a nivel físico como lógico.



Fig.1. La seguridad pasiva, fundamental en un datacenter.

A continuación, vamos a plantear un caso práctico a través del cual podremos aproximarnos de forma práctica a la teoría de este tema.

Escucha el siguiente audio donde planteamos la contextualización práctica de este tema. Encontrarás su resolución en el apartado 'Resumen y resolución del caso práctico'.

Audio Intro. *"La seguridad de la empresa TechSolutions"*

https://bit.ly/42jvogf

2. Pautas de seguridad informática

Las pautas de seguridad informática son un aspecto fundamental para garantizar la protección de los sistemas, datos y recursos en el entorno digital. Estas pautas establecen las mejores prácticas y directrices que deben seguirse para implementar medidas de seguridad eficaces y mitigar los riesgos asociados a posibles amenazas y ataques cibernéticos.

Sabías que...

Según un informe de Verizon de 2020, se descubrió que el 85% de las brechas de seguridad fueron causadas por ataques que podrían haberse evitado si se hubieran seguido pautas básicas de seguridad.

Existen diversas **organizaciones y estándares reconocidos** a nivel mundial que proporcionan pautas de seguridad informática ampliamente aceptadas y adoptadas en diferentes sectores. Algunos ejemplos son:



Fig.2. Los estándares, clave en la adopción de pautas.

1. **ISO/IEC 27001**: Este estándar internacional establece los requisitos para establecer, implementar, mantener y mejorar un sistema de gestión de seguridad de la información. Proporciona un enfoque integral para la gestión de riesgos y la implementación de controles de seguridad.

2. **NIST Cybersecurity Framework**: Desarrollado por el Instituto Nacional de Estándares y Tecnología (NIST) de Estados Unidos, este marco de trabajo proporciona una guía detallada para mejorar la capacidad de una organización para prevenir, detectar y responder a los ataques cibernéticos. Se basa en cinco funciones principales: identificar, proteger, detectar, responder y recuperarse.

3. **CIS Controls**: La lista de controles de seguridad del Center for Internet Security (CIS) es un conjunto de prácticas de seguridad informática que ofrece una base sólida para mejorar la seguridad. Los controles están organizados en tres niveles, desde los más básicos hasta los más avanzados, y cubren una amplia gama de áreas de seguridad.

Estas organizaciones y estándares desempeñan un papel fundamental en el establecimiento de buenas prácticas y directrices en el campo de la seguridad informática. Además, tienen como objetivo **promover la seguridad de la información, facilitar la colaboración entre industrias y proporcionar un marco común para que las organizaciones implementen medidas de seguridad efectivas**.

A continuación un audio sobre qué organizaciones se encargan de establecer las pautas de seguridad:

Audio 1. *"¿Qué organizaciones se encargan de establecer las pautas de seguridad?"*

https://bit.ly/43DjTku

2. 1. Adopción de las pautas

La adopción de pautas y estándares de seguridad informática requiere un enfoque integral que involucre a la alta dirección, TI y seguridad. Las **acciones clave** incluyen:

1. **Evaluación de riesgos**: Identificar amenazas internas y externas, así como su impacto potencial.
2. **Diseño y arquitectura segura**: Crear infraestructuras protegidas mediante segmentación, cifrado y control de accesos.
3. **Políticas y procedimientos**: Definir normas claras sobre acceso, contraseñas, uso de recursos y respuesta a incidentes.



Fig.3. Equipo trabajando en la adopción de pautas de seguridad.

4. **Capacitación y concienciación**: Educar al personal para fomentar una cultura de seguridad organizacional.
5. **Monitoreo y mejora continua**: Implementar herramientas de detección, realizar auditorías, pruebas de penetración y ajustes ante nuevas amenazas.

La participación de toda la organización es clave para detectar amenazas, cumplir regulaciones y proteger la cadena de suministro. La seguridad debe ser responsabilidad compartida para salvaguardar activos y reputación.

2. 2. Impactos y repercusión

Adoptar pautas de seguridad genera múltiples **impactos**:

1. **Protección de información sensible**: Salvaguarda la confidencialidad, integridad y disponibilidad de datos.
2. **Prevención de ciberataques**: Minimiza riesgos mediante controles como firewalls y autenticación robusta.

3. **Cumplimiento legal**: Alinea la operación con regulaciones, evitando sanciones y mejorando la imagen.

4. **Continuidad del negocio**: Reduce tiempos de inactividad y evita pérdidas económicas.

5. **Confianza y reputación**: Fortalece la imagen organizacional ante clientes y socios.

6. **Ahorro de costos**: Previene gastos por incidentes, restauración de sistemas o pérdida de datos.



Fig.4. La confianza crece en una empresa comprometida con la seguridad.

3. Caso práctico 1: "Implementamos medidas de seguridad en nuestra red doméstica"

Planteamiento: Un día, Juan recibe un correo electrónico sospechoso que le solicita que haga clic en un enlace adjunto. Sin embargo, gracias a su conocimiento sobre phishing y buenas prácticas de seguridad, reconoce las señales de advertencia y evita hacer clic en el enlace. En su lugar, decide investigar más sobre el correo electrónico y descubre que se trata de un intento de estafa.

Nudo: Inspirado por su experiencia, Juan decide implementar medidas de seguridad adicionales en su red doméstica. ¿Podrías indicar una serie de buenas prácticas para mejorar la seguridad de la red doméstica de Juan?



Fig.5. Esquema de una red doméstica.

Desenlace: Existen varias medidas de seguridad adicionales que se pueden implementar en una red doméstica para mejorar su seguridad. Algunas pueden ser:

1. **Actualizar regularmente el software**: Mantener actualizado el software de todos los dispositivos conectados a la red. Las actualizaciones suelen incluir parches de seguridad que corrigen vulnerabilidades conocidas.

2. **Configurar una red wifi segura**: Cambiar el nombre de la red wifi (SSID) y establecer una contraseña fuerte y única. Se recomienda utilizar cifrado WPA2 o WPA3.

3. **Configurar un firewall**: Activar el firewall integrado en el rúter para filtrar el tráfico no deseado y proteger la red contra posibles ataques externos.

4. **Utilizar contraseñas fuertes**: Establecer contraseñas sólidas y únicas para el rúter, las cuentas y todos los dispositivos conectados. Las contraseñas deben ser largas, combinar letras, números y símbolos, y evitarse contraseñas comunes o fáciles de adivinar.

5. **Desactivar servicios no utilizados**: Desactivar servicios o puertos que no se estén utilizando en el rúter para reducir la superficie de ataque.

6. **Habilitar el filtrado de direcciones MAC**: Configurar el rúter para que solo permita la conexión de dispositivos cuyas direcciones MAC estén en una lista de acceso.

7. **Utilizar un software de seguridad**: Instalar y mantener actualizado un software antivirus y antimalware en todos los dispositivos conectados a la red doméstica.

8. **Realizar copias de seguridad regulares**: Realizar copias de seguridad de los datos importantes en un dispositivo externo o en la nube para protegerse contra la pérdida de datos en caso de un incidente de seguridad o fallo.

9. **Educación y concienciación**: Brindar educación sobre seguridad informática a todos los miembros de la familia, incluyendo buenas prácticas de seguridad, cómo reconocer correos electrónicos de phishing y evitar hacer clic en enlaces sospechosos.

4. Seguridad física y ambiental

La seguridad física y ambiental se enfoca en **proteger los activos físicos y el entorno en el que operan los sistemas informáticos**. Aunque a menudo se subestima, este aspecto juega un papel crítico en la protección de la información y los recursos tecnológicos. Algunos **puntos clave** relacionados con estos aspectos de seguridad son:

1. **Acceso físico restringido**: Es importante garantizar que solo las personas autorizadas tengan acceso físico a los espacios donde se encuentran los sistemas y datos críticos. Esto implica el uso de medidas de control de acceso, como cerraduras, tarjetas de acceso, sistemas de autenticación biométrica o vigilancia por vídeo para supervisar y restringir el acceso no autorizado.

2. **Protección contra intrusiones físicas**: Además del control de acceso, se deben implementar medidas de protección física para evitar intrusiones no autorizadas. Esto puede incluir la instalación de sistemas de alarmas, cámaras de seguridad, barreras físicas, como cercas o puertas de seguridad, y la utilización de personal de seguridad o servicios de vigilancia.

3. **Respaldo y protección de datos físicos**: Además de proteger los sistemas informáticos, es crucial salvaguardar los datos físicos, como copias de seguridad, discos duros externos o documentos impresos. Esto puede lograrse almacenándolos en áreas seguras, como cajas fuertes o salas con control de acceso, y estableciendo políticas de gestión de documentos que incluyan su destrucción segura cuando ya no sean necesarios.

4. **Protección contra desastres y fallas ambientales**: Los desastres naturales, como incendios, inundaciones o terremotos, así como fallas ambientales, como problemas de temperatura o humedad, pueden dañar los equipos y poner en riesgo la continuidad del negocio. Es importante implementar medidas como sistemas de detección y extinción de incendios, sistemas de alimentación ininterrumpida (SAI), sistemas de control de temperatura y humedad, y realizar copias de seguridad fuera del sitio para mitigar estos riesgos.



Fig.6. Incendio en una oficina.

5. **Eliminación segura de dispositivos**: Al final de su ciclo de vida útil, los dispositivos electrónicos deben ser desechados de manera segura para evitar la exposición de información confidencial. Esto implica la eliminación adecuada de datos mediante técnicas de borrado seguro o destrucción física de los dispositivos.

Recuerda que...

La seguridad física y ambiental es una parte integral de una estrategia de seguridad informática sólida. Al proteger los activos físicos, se reduce el riesgo de acceso no autorizado, daños físicos y pérdida de información.

4. 1. Ubicación y protección física de los equipos y servidores

La ubicación y protección física de los equipos y servidores es esencial para garantizar la seguridad y la integridad de los datos y sistemas de una organización. Aquí se presentan algunos **aspectos clave** relacionados con este tema:

1. **Ubicación estratégica**: Los equipos y servidores deben ubicarse en áreas seguras y controladas, lejos de posibles amenazas físicas. Se recomienda tener una sala de servidores dedicada con acceso restringido, protegida contra condiciones ambientales adversas y alejada de áreas de alto tráfico o posibles riesgos, como inundaciones o áreas propensas a desastres naturales.

2. **Control de accesos**: El acceso a las áreas donde se encuentran los equipos y servidores debe estar restringido únicamente a personal autorizado. Esto se logra mediante el uso de sistemas de control de acceso físico, como cerraduras con tarjetas de identificación, biométricos o llaves físicas, junto con la supervisión constante del personal de seguridad.

3. **Sistemas de vigilancia**: Es importante implementar sistemas de vigilancia, como cámaras de seguridad, para monitorear el entorno donde se encuentran los equipos y servidores. Estos sistemas pueden ayudar a detectar y registrar cualquier actividad sospechosa o intrusión física.



Fig.7. Es importante mantener la vigilancia física.

4. **Protección del hardware**: Se deben implementar sistemas de detección y extinción de incendios, como detectores de humo, sistemas de supresión de incendios y extinguidores, para proteger los equipos y servidores contra los riesgos de incendios. Además, es recomendable mantener un plan de evacuación y realizar simulacros periódicos para asegurar una respuesta adecuada en caso de emergencia.

5. **Condiciones ambientales**: Los equipos y servidores son sensibles a las variaciones de temperatura y humedad. Por lo tanto, es importante mantener un entorno controlado con sistemas de refrigeración adecuados, como aires acondicionados o sistemas de enfriamiento por agua, y controlar los niveles de humedad para evitar daños.

6. **Registro y seguimiento**: Es importante mantener un registro de todas las actividades relacionadas con la ubicación y el acceso a los equipos y servidores. Esto incluye registros de ingreso, salidas y cualquier cambio realizado en el entorno o en los sistemas. Además, se deben establecer políticas y procedimientos claros para el seguimiento y la auditoría regular de estos registros.

Vídeo 1. *"El uso de registros o logs para la seguridad del sistema"*

https://bit.ly/43DySuQ

4. 2. Plan de seguridad física

El desarrollo de un plan de seguridad física efectivo implica **seguir una serie de pasos** que pueden ser los siguientes:

1. **Evaluar los riesgos**: Realizar una evaluación de los riesgos y las amenazas físicas.

2. **Establecer objetivos de seguridad**: Definir los objetivos específicos de seguridad física que se desean.

3. **Diseñar medidas de seguridad**: En base a los riesgos identificados y los objetivos establecidos, se debe desarrollar una estrategia de seguridad física que incluya medidas y controles adecuados.

4. **Establecer políticas y procedimientos**: Definir políticas y procedimientos claros para el personal de seguridad y otros empleados en relación con la seguridad física.

5. **Implementar medidas de seguridad**: Llevar a cabo la implementación de las medidas de seguridad física planificadas.

6. **Monitorear y evaluar**: Establecer un sistema de monitoreo continuo de las medidas de seguridad física implementadas.

7. **Actualizar y mejorar**: Mantener el plan de seguridad física actualizado y ajustado a medida que cambien los riesgos y las necesidades de la organización.

A continuación un recordatorio sobre buscar asesoramiento de expertos:

Recuerda que...

Cada organización es única y puede requerir enfoques específicos en sus planes. Es recomendable buscar asesoramiento de expertos y considerar las regulaciones y normativas locales al desarrollar e implementar estos planes.

4. 3. Plan de recuperación en caso de desastres

Un plan de recuperación en caso de desastres (**DRP**, por sus siglas en inglés) es un conjunto de procedimientos y medidas diseñados para ayudar a una organización a recuperarse y restaurar sus operaciones en caso de un desastre o interrupción significativa. Aquí hay una breve **descripción de los aspectos clave** de un plan de recuperación en caso de desastres:

1. **Evaluación de impacto en el negocio (BIA, por sus siglas en inglés)**: El primer paso en el desarrollo de un DRP es realizar una evaluación exhaustiva de los impactos potenciales de un desastre en las operaciones de la organización.

2. **Estrategias de recuperación**: Una vez que se comprenden los impactos en el negocio, se desarrollan estrategias de recuperación apropiadas.

3. **Planes de acción**: Un DRP debe incluir planes de acción detallados que describan los pasos específicos a seguir en caso de un desastre.



Fig.8. Un DRP es fundamental para recuperar el normal funcionamiento de los sistemas en caso de incendio.

4. **Respuesta a emergencias**: Un DRP debe abordar también la respuesta inicial a una emergencia.

5. **Pruebas y mantenimiento**: Es esencial realizar pruebas periódicas del plan de recuperación en caso de desastres para asegurarse de que sea efectivo y esté actualizado.

5. Caso práctico 2: “Ideamos nuestro plan de seguridad física”

Planteamiento: Se nos ha encargado desarrollar el plan de seguridad física de nuestra empresa.

Nudo: A partir de los puntos que se deben incluir en este plan, tal y como hemos estudiado en el tema, ¿serías capaz de describir ejemplos concretos para incluirlos en el plan?

Desenlace: En el plan de seguridad física:

1. **Evaluar los riesgos**: Podemos incluir riesgos como intrusión, robo, vandalismo, incendios, inundaciones o desastres naturales. Identifica los activos críticos que requieren protección, como equipos, servidores, documentos importantes o áreas de acceso restringido.

2. **Establecer objetivos de seguridad**: Debemos incluir la protección de activos físicos, la prevención de acceso no autorizado, la mitigación de riesgos y la garantía de la continuidad del negocio en caso de emergencias.



Fig.9. Diseño de un plan de seguridad física.

3. **Diseñar medidas de seguridad**: Podrían ser cámaras de seguridad, sistemas de control de acceso, sistemas de alarma, sistemas de detección de incendios, sistemas de respaldo de energía y sistemas de vigilancia, entre otros.

4. **Establecer políticas y procedimientos**: Debemos abordar aspectos como el control de acceso, el manejo de visitantes, la gestión de llaves, el registro y seguimiento de incidentes, y la respuesta a emergencias.

5. **Implementar medidas de seguridad**: Podemos instalar los sistemas de seguridad, configurar los controles de acceso, capacitar al personal de seguridad y comunicar a los empleados las políticas y los procedimientos de seguridad física.

6. **Monitorear y evaluar**: Podríamos incluir la supervisión de las cámaras de seguridad, la revisión regular de los registros de acceso, el mantenimiento y prueba de los sistemas de seguridad, y la realización de auditorías de seguridad física.

7. **Actualizar y mejorar**: Nos aseguraremos de revisar y actualizar regularmente las políticas, los procedimientos y las medidas de seguridad física en función de las lecciones aprendidas, los cambios en la infraestructura y los avances en la tecnología de seguridad.

6. Sistemas de alimentación ininterrumpida (SAI)

Los Sistemas de Alimentación Ininterrumpida (SAI), también conocidos como UPS (*Uninterruptible Power Supply*, por sus siglas en inglés), son dispositivos diseñados para **proporcionar energía eléctrica continua y sin interrupciones a los equipos conectados**, incluso en casos de cortes de energía eléctrica. Estos sistemas desempeñan un papel fundamental en la protección de los equipos y la garantía de la continuidad del negocio.

6. 1. Funciones

1. **Suministro de energía continua**: La función principal de un SAI es proporcionar energía eléctrica continua y estable a los equipos conectados, incluso en situaciones de cortes de energía o fluctuaciones en el suministro eléctrico.

2. **Protección contra sobretensiones y fluctuaciones**: Los SAI protegen los equipos conectados contra sobretensiones y fluctuaciones en la red eléctrica, evitando posibles daños causados por picos de voltaje o caídas de voltaje bruscas.

3. **Tiempo de respaldo**: Los SAI están equipados con baterías internas que permiten mantener el suministro de energía durante un periodo determinado en caso de un corte de energía. El tiempo de respaldo varía según la capacidad de las baterías y la carga conectada al SAI.

6. 2. Tipos

1. **SAI en línea (online UPS)**: Es el tipo más avanzado y completo de SAI. En este sistema, la carga siempre está alimentada por la batería y la energía de la red eléctrica se utiliza para recargar la batería. Proporciona una energía de salida de alta calidad y protección contra todas las anomalías eléctricas.

2. **SAI en línea de doble conversión (Double Conversion Online UPS)**: Es una variante del SAI en línea. En este caso, la energía de la red eléctrica se convierte en corriente continua (mediante un rectificador) y luego se convierte nuevamente en corriente alterna (mediante un inversor) para alimentar los equipos. Esto proporciona una mayor protección y estabilidad.

3. **SAI de línea** interactiva (Line Interactive UPS): Este tipo de SAI combina características de los SAI en línea y los SAI de reserva. La energía de la red eléctrica se utiliza para alimentar directamente la carga, pero también se carga una batería interna para proporcionar respaldo en caso de cortes de energía.



Fig.10. Detalle en primer plano de un SAI.

4. **SAI de reserva (Standby UPS)**: Es el tipo más básico de SAI. La carga se alimenta directamente desde la red eléctrica y solo se activa la batería interna cuando se produce un corte de energía. Proporciona una protección básica contra cortes de energía y fluctuaciones, pero puede haber una pequeña interrupción en el suministro durante la transición a la batería.

7. Resumen y resolución del caso práctico de la unidad

En este tema se abordan los principales aspectos de la seguridad pasiva en el entorno profesional. Se destaca la importancia de adoptar pautas de seguridad que involucren a todo el personal, fomentando una cultura organizativa orientada a la protección de la información y los activos.

Se analiza el papel de las organizaciones y los estándares internacionales, que proporcionan marcos y directrices para implementar buenas prácticas de seguridad. Además, se profundiza en la seguridad física y ambiental, resaltando la necesidad de proteger los equipos, servidores y demás infraestructuras frente a amenazas físicas, fallos técnicos o desastres naturales.

Finalmente, se subraya la importancia de diseñar planes específicos: un plan de seguridad física, que contemple controles de acceso y medidas de protección, y un plan de recuperación ante desastres, que permita garantizar la continuidad de las operaciones y una respuesta eficaz ante emergencias.

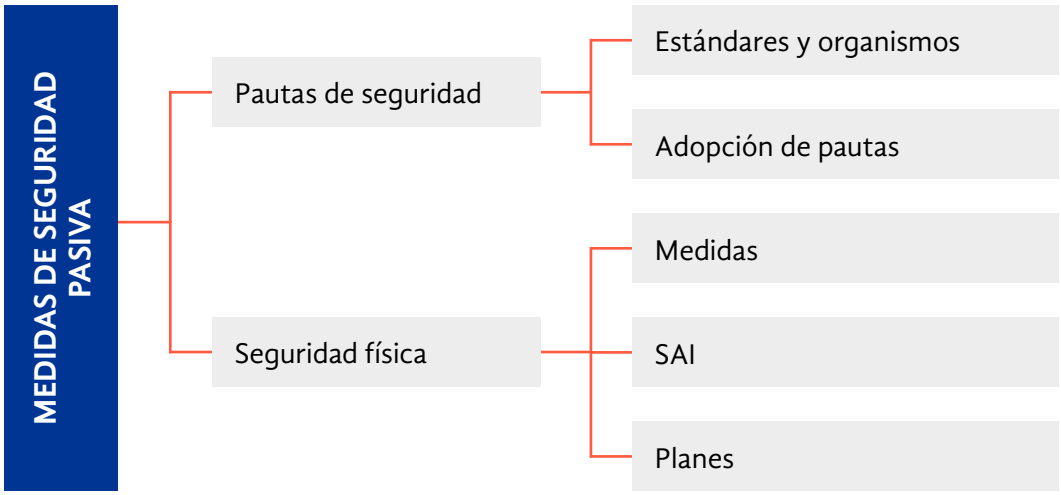


Fig.11. Esquema resumen del tema.

Resolución del caso práctico de la unidad

El Plan de Recuperación ante Desastres (DRP) de TechSolutions busca minimizar el impacto de desastres y garantizar la continuidad de las operaciones. Un esquema básico del plan podría incluir:

1. **Identificación de riesgos**: Enumerar posibles desastres, como incendios, fallos del sistema, ciberataques o desastres naturales.

2. **Respaldo de datos**: Asegurar que los datos críticos estén respaldados en ubicaciones fuera del sitio, como en la nube o servidores externos.

3. **Recuperación de infraestructuras**: Establecer procedimientos para restaurar servidores, redes y aplicaciones, priorizando los servicios críticos.

4. **Redundancia de sistemas**: Implementar infraestructura redundante (servidores de respaldo, redes alternativas) para mantener operaciones en caso de fallos.

5. **Pruebas periódicas**: Realizar pruebas regulares del plan para garantizar su efectividad y detectar áreas de mejora.

8. Bibliografía

National Institute of Standards and Technology (NIST) (2018). *NIST Special Publication 800-53: Security and Privacy Controls for Federal Information Systems and Organizations.* Recuperado de: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf

International Organization for Standardization (ISO) (2019). ISO/*IEC 27001:2013 Information technology – Security techniques – Information security management systems – Requirements.* Recuperado de: https://www.iso.org/standard/54534.html

Open Web Application Security Project (OWASP) (2021). *OWASP Top Ten Project*. Recuperado de: https://owasp.org/www-project-top-ten/

US-CERT (2018). *Cybersecurity Framework*. Recuperado de: https://www.cisa.gov/

Mell, P., & Grance, T. (2011). *The NIST definition of cloud computing.* Recuperado de: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-145.pdf